

API Specification

REST API Documentation

Version: 1.0
Datum: 2026-01-07
Base URL: <https://api.yourdomain.com/api/v1>

API Overview

Detta dokument beskriver REST API:et för SaaS-bokningssystemet. API:et följer RESTful-principer och använder JSON för request/response bodies.

- **Base URL:** `https://api.yourdomain.com/api/v1`
- **Authentication:** Bearer JWT tokens
- **Content-Type:** `application/json`
- **Encoding:** UTF-8
- **Date Format:** ISO 8601 (YYYY-MM-DDTHH:mm:ssZ)
- **Versioning:** URL-based (`/api/v1/`)
- **Rate Limiting:** 100 requests/minute per user

Authentication & Authorization

JWT Token Structure

Efter lyckad inloggning får klienten en JWT token som inkluderas i Authorization header:

```
Authorization: Bearer {token}
```

Token Claims:

- `sub` (Subject) - UserId
- `email` - Användarens e-post
- `tenant_id` - TenantId
- `role` - Användarens roller (array)
- `exp` - Expiration timestamp
- `iat` - Issued at timestamp

Standard HTTP Response Codes

Code	Meaning	När används
200	OK	Lyckad GET, PUT, PATCH request
201	Created	Lyckad POST request, resurs skapad
204	No Content	Lyckad DELETE request
400	Bad Request	Ogiltig input, validering misslyckades
401	Unauthorized	Ingen eller ogiltig token
403	Forbidden	Token giltig men användaren saknar behörighet
404	Not Found	Resursen finns inte
409	Conflict	Konflikt (ex. dubbelbokning)
422	Unprocessable Entity	Validering misslyckades (detaljerad)
429	Too Many Requests	Rate limit överskriden
500	Internal Server Error	Oväntat serverfel

Error Response Format

```
{
  "type": "https://tools.ietf.org/html/rfc7231#section-6.5.1",
  "title": "One or more validation errors occurred.",
  "status": 400,
  "traceId": "00-123abc...",
  "errors": {
    "Email": ["The Email field is required."],
    "Password": ["Password must be at least 8 characters."]
  }
}
```

Authentication Endpoints

POST /auth/register

Registrera ny organisation (tenant) och owner.

Request Body:

```
{
  "organizationName": "Acme Corp",
  "email": "owner@acme.com",
  "password": "SecurePass123!",
  "firstName": "John",
  "lastName": "Doe",
  "phoneNumber": "+46701234567"
}
```

Response (201):

```
{
  "userId": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
  "tenantId": "7f8d9e0a-1b2c-3d4e-5f6g-7h8i9j0k1l2m",
  "email": "owner@acme.com",
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "abc123...",
  "expiresIn": 1800
}
```

POST /auth/login

Logga in med e-post och lösenord.

Request Body:

```
{
  "email": "user@acme.com",
  "password": "SecurePass123!"
}
```

Response (200):

```
{
  "userId": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
  "tenantId": "7f8d9e0a-1b2c-3d4e-5f6g-7h8i9j0k1l2m",
  "email": "user@acme.com",
  "firstName": "Jane",
  "lastName": "Smith",
  "role": "User",
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "def456...",
}
```

```
"expiresIn": 1800
}
```

POST /auth/refresh

Förnya access token med refresh token.

Request Body:

```
{
  "refreshToken": "def456..."
}
```

User Management Endpoints

GET /users

Hämta alla användare i tenant. **Requires:** Admin or Owner role

Query Parameters:

- pageNumber (int, default: 1)
- pageSize (int, default: 20, max: 100)
- search (string) - Sök i namn eller e-post
- status (Active/Inactive/Invited)
- role (Owner/Admin/User)

Response (200):

```
{
  "data": [
    {
      "id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
      "email": "user@acme.com",
      "firstName": "Jane",
      "lastName": "Smith",
      "phoneNumber": "+46701234567",
      "status": "Active",
      "roles": ["User"],
      "emailVerified": true,
      "lastLoginAt": "2026-01-07T10:30:00Z",
      "createdAt": "2026-01-01T09:00:00Z"
    }
  ],
  "pageNumber": 1,
  "pageSize": 20,
  "totalPages": 1,
  "totalCount": 1
}
```

GET /users/{id}

Hämta specifik användare. **Requires:** Admin eller egen användare

POST /invites

Bjud in ny användare till tenant. **Requires:** Admin or Owner

Request Body:

```
{
```

```
"email": "newuser@example.com",
"roleId": "user-role-guid",
"firstName": "New",
"lastName": "User"
}
```

Response (201):

```
{
  "inviteId": "abc-def-...",
  "email": "newuser@example.com",
  "status": "Pending",
  "expiresAt": "2026-01-14T09:00:00Z",
  "inviteUrl": "https://yourdomain.com/accept-invite?token=xyz123..."
}
```

POST /invites/accept

Acceptera inbjudan och aktivera konto. **Public endpoint**

Request Body:

```
{
  "token": "xyz123...",
  "password": "SecurePass123!",
  "firstName": "Updated",
  "lastName": "Name"
}
```

BookingType Endpoints

POST /booking-types

Skapa ny bokningstyp. **Requires:** Admin or Owner

Request Body:

```
{
  "name": "Conference Room Booking",
  "description": "Book our conference rooms",
  "durationMinutes": 60,
  "maxAdvanceBookingDays": 30,
  "maxBookingsPerUser": 3,
  "isActive": true,
  "color": "#3b82f6",
  "requiresApproval": false
}
```

Response (201):

```
{
  "id": "bt-guid-123",
  "tenantId": "tenant-guid",
  "name": "Conference Room Booking",
  "description": "Book our conference rooms",
  "durationMinutes": 60,
  "maxAdvanceBookingDays": 30,
  "maxBookingsPerUser": 3,
  "isActive": true,
  "color": "#3b82f6",
  "requiresApproval": false,
  "createdAt": "2026-01-07T10:00:00Z"
}
```

GET /booking-types

Hämta alla bokningstyper för tenant.

Query Parameters:

- isActive (bool) - Filtrera på aktiva/inaktiva
- includeResources (bool) - Inkludera associerade resurser

PUT /booking-types/{id}

Uppdatera bokningstyp. **Requires:** Admin or Owner

DELETE /booking-types/{id}

Ta bort (soft delete) bokningstyp. **Requires:** Admin or Owner

Resource Endpoints

POST /resources

Skapa ny resurs. **Requires:** Admin or Owner

Request Body:

```
{
  "name": "Conference Room A",
  "description": "Large room with projector",
  "type": "Room",
  "capacity": 12,
  "location": "Building 1, Floor 2",
  "isActive": true,
  "imageUrl": "https://cdn.example.com/room-a.jpg"
}
```

GET /resources

Hämta alla resurser för tenant.

Query Parameters:

- type (Room/Equipment/Person/Other)
- isActive (bool)
- pageNumber, pageSize

Booking Endpoints

GET /bookings/available-slots

Hämta tillgängliga bokningsbara tider.

Query Parameters (Required):

- bookingTypeId (guid) - Vilken bokningstyp
- startDate (date) - Från datum (YYYY-MM-DD)
- endDate (date) - Till datum (YYYY-MM-DD)
- resourceId (guid, optional) - Specifik resurs

Response (200):

```
{
  "bookingTypeId": "bt-guid-123",
  "bookingTypeName": "Conference Room Booking",
  "durationMinutes": 60,
  "availableSlots": [
    {
      "startTime": "2026-01-08T09:00:00Z",
      "endTime": "2026-01-08T10:00:00Z",
      "resourceId": "resource-guid",
      "resourceName": "Conference Room A"
    },
    {
      "startTime": "2026-01-08T10:00:00Z",
      "endTime": "2026-01-08T11:00:00Z",
      "resourceId": "resource-guid",
      "resourceName": "Conference Room A"
    }
  ]
}
```

POST /bookings

Skapa ny bokning. **Requires:** User role

Request Body:

```
{
  "bookingTypeId": "bt-guid-123",
  "resourceId": "resource-guid",
  "startTime": "2026-01-08T09:00:00Z",
  "notes": "Team meeting for Q1 planning"
}
```

Response (201):

```
{
  "id": "booking-guid",
  "userId": "user-guid",
  "bookingTypeId": "bt-guid-123",
  "bookingTypeName": "Conference Room Booking",
  "resourceId": "resource-guid",
  "resourceName": "Conference Room A",
  "startTime": "2026-01-08T09:00:00Z",
  "endTime": "2026-01-08T10:00:00Z",
  "status": "Confirmed",
  "notes": "Team meeting for Q1 planning",
  "createdAt": "2026-01-07T14:30:00Z"
}
```

Validation Rules:

- StartTime måste vara i framtiden
- Får inte överlappa med annan bokning för samma resurs
- Måste vara inom maxAdvanceBookingDays
- Användaren får inte överskrida maxBookingsPerUser (aktiva bokningar)

GET /bookings

Hämta bokningar. User ser endast sina egna, Admin ser alla.

Query Parameters:

- userId (guid, admin only) - Filtrera på användare
- resourceId (guid) - Filtrera på resurs
- bookingTypeId (guid) - Filtrera på bokningstyp
- status (Pending/Confirmed/Cancelled)
- startDate, endDate - Datumintervall
- pageNumber, pageSize

DELETE /bookings/{id}

Avboka en bokning. Användare kan avboka sina egna, Admin kan avboka alla.

Request Body (Optional):

```
{  
  "cancellationReason": "Meeting cancelled due to illness"  
}
```

Pagination & Filtering

Standard Pagination

Alla list-endpoints stödjer pagination med följande query parameters:

- **pageNumber** (int, default: 1) - Sidnummer att hämta
- **pageSize** (int, default: 20, max: 100) - Antal items per sida

Pagination Response Format

```
{
  "data": [...],
  "pageNumber": 1,
  "pageSize": 20,
  "totalPages": 5,
  "totalCount": 87,
  "hasPreviousPage": false,
  "hasNextPage": true
}
```

Rate Limiting

API:et har rate limits för att skydda mot abuse och säkerställa fair usage:

- **Authenticated requests:** 100 requests/minute per user
- **Authentication endpoints:** 10 requests/minute per IP
- **Public endpoints:** 20 requests/minute per IP

Rate Limit Headers

Varje response inkluderar följande headers:

- X-RateLimit-Limit: 100
- X-RateLimit-Remaining: 87
- X-RateLimit-Reset: 1641556800

När rate limit överskrids returneras **429 Too Many Requests** med Retry-After header.

CORS (Cross-Origin Resource Sharing)

API:et stödjer CORS för att tillåta frontend-applikationer från andra domäner:

- Access-Control-Allow-Origin: <https://app.yourdomain.com>
- Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
- Access-Control-Allow-Headers: Content-Type, Authorization
- Access-Control-Max-Age: 86400

Webhooks (Future Feature)

I framtida versioner kommer API:et stödja webhooks för real-time notifications. Detta är **utanför MVP-scope**.

- booking.created - Ny bokning skapad
- booking.cancelled - Bokning avbokad
- booking.updated - Bokning uppdaterad
- user.invited - Användare inbjuden
- user.activated - Användare aktiverade sitt konto

API Versioning Strategy

Vi använder **URL-based versioning** för tydlighet och enkelhet:

- **Current:** /api/v1/bookings
- **Future:** /api/v2/bookings
- Gamla versioner depreceras med 6 månaders varsel
- Deprecated endpoints returnerar X-API-Deprecated header
- Breaking changes kräver ny major version

Testing & Development

Swagger/OpenAPI

API:et har automatisk OpenAPI-dokumentation tillgänglig på:

- **Production:** <https://api.yourdomain.com/swagger>
- **Staging:** <https://api-staging.yourdomain.com/swagger>

Postman Collection

En komplett Postman collection med alla endpoints och exempel kommer att tillhandahållas.

Sandbox/Demo Environment

En sandbox-miljö med demo-data finns tillgänglig för testing:

- **URL:** <https://api-sandbox.yourdomain.com>
- **Demo credentials:** demo@example.com / DemoPass123!
- **Reset:** Data resettas dagligen kl 02:00 UTC

Best Practices för API-användning

- **Använd HTTPS:** Skicka alltid requests över HTTPS, aldrig HTTP
- **Lagra tokens säkert:** Använd secure storage, inte localStorage för JWT tokens
- **Implementera retry logic:** Hantera 429 och 5xx errors med exponential backoff
- **Cache responses:** Använd ETags och If-None-Match headers där möjligt
- **Validera input:** Validera på klient-sidan före API-anrop
- **Hantera errors:** Implementera proper error handling för alla response codes
- **Använd pagination:** Använd alltid pagination för list endpoints
- **Respektera rate limits:** Övervaka X-RateLimit headers och justera anropshastighet
- **Logga errors:** Logga API-errors med traceId för felsökning
- **Keep tokens fresh:** Förnya tokens proaktivt innan de går ut

Support & Resources

API Documentation: <https://docs.yourdomain.com>

OpenAPI Spec: <https://api.yourdomain.com/swagger/v1/swagger.json>

Status Page: <https://status.yourdomain.com>

Support Email: api-support@yourdomain.com

GitHub Issues: <https://github.com/yourorg/booking-api/issues>

Developer Forum: <https://forum.yourdomain.com>